

CRAFT — Pitch Package

Audited retrieval-augmented AI assistant for CSA mission engineering and finance.

1. Design & Architecture (L2)

L2 · Containers · Actors · External Systems

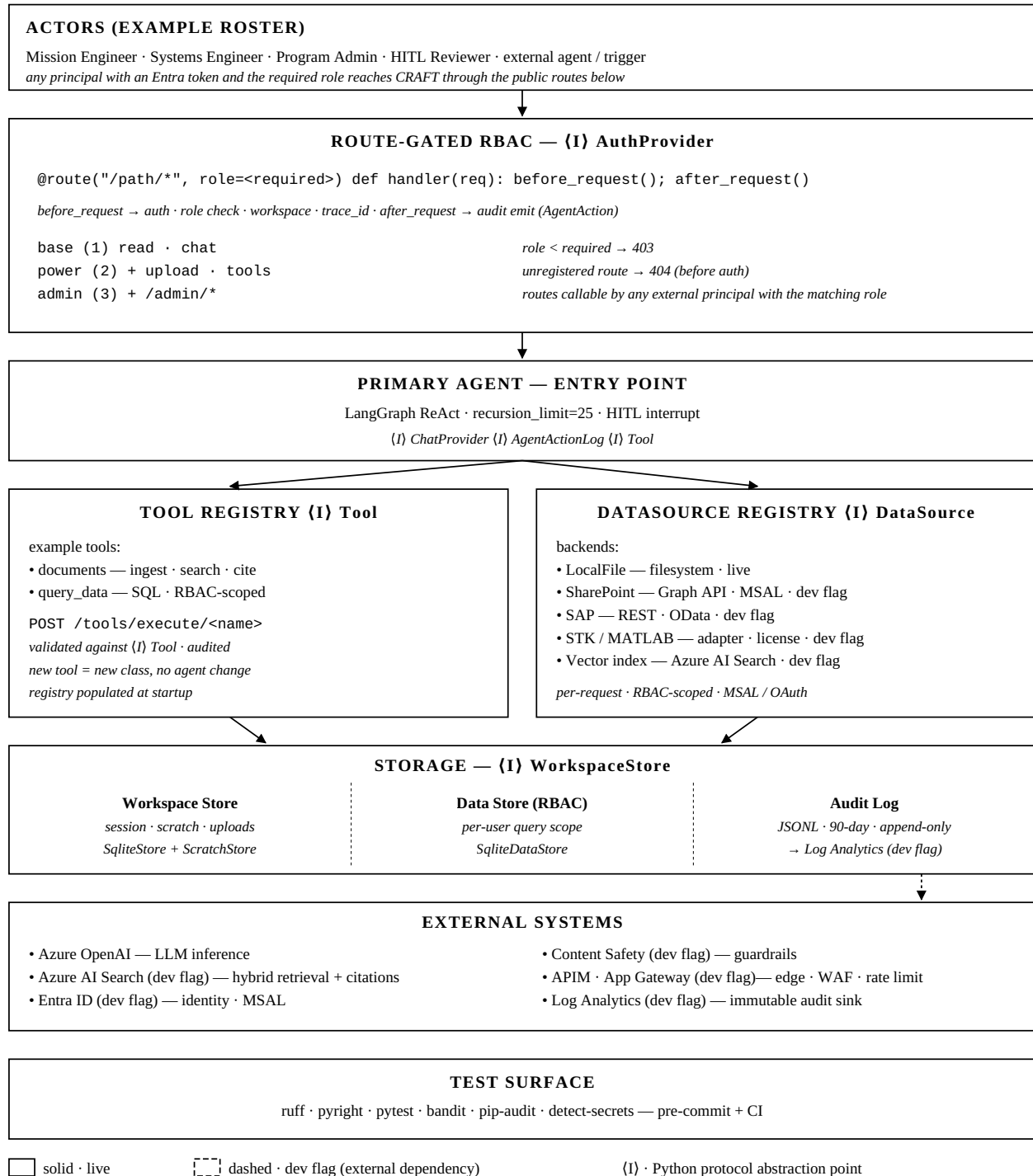


Figure 1 · Actors, routes, containers, data, external systems, and the audit perimeter.

The system is a Flask + Dash application fronted by a route-gated RBAC layer. The design decision driving everything else: **every entry point is a REST route, every route is role-checked, and every step emits an audit record**. That shape lets the Primary Agent, the Tool Registry, and the DataSource Registry stay loosely coupled behind Python protocols — the agent calls /tools/execute/<name> and

never knows which concrete tool runs; a tool queries through `(I) DataSource` and never knows whether it's reading a local file or SharePoint. The audit log sits across all three so trace reconstruction stays complete regardless of which backend serves a given call.

Choosing Flask over a heavier framework was deliberate: it keeps the public surface a plain HTTP API that any external agent, scheduler, or CI runner can hit directly, so the whole product is deployable anywhere a container runs and callable from anywhere a trigger lives — a Teams bot, a cron job, an upstream orchestrator agent. Dash is used only for the HITL reviewer UI, which lives inside the same auth perimeter and talks to the same routes.

2. Internals (L3)

L3 · Internal Clusters

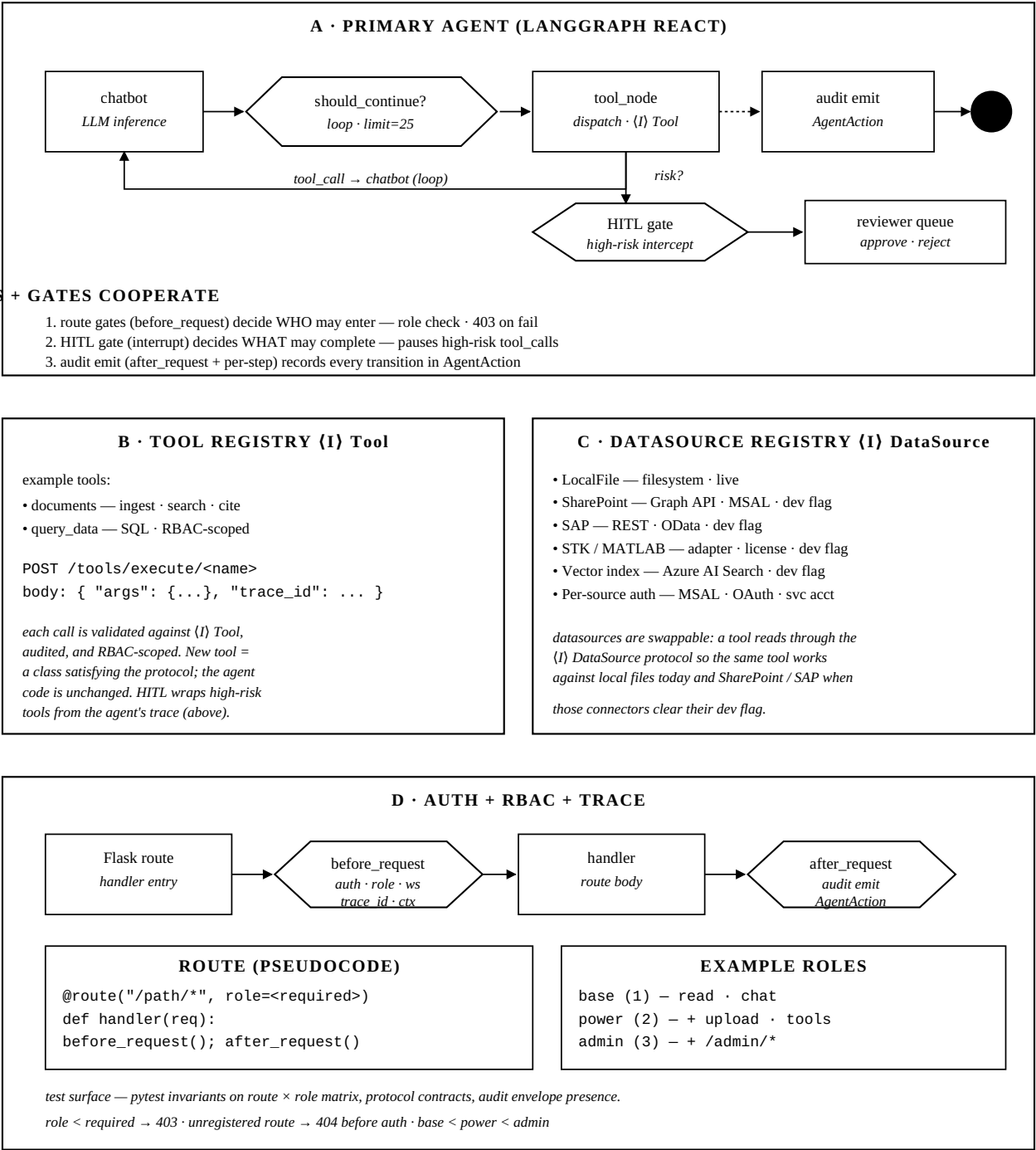


Figure 2 · Agent loop with HITL branch, tool registry, data-source registry, and auth cluster.

The Primary Agent is a LangGraph ReAct graph with `recursion_limit = 25` and a HITL interrupt branch off the `tool_node`. Routes gate who may enter; the HITL gate decides what may complete. Both are first-class graph edges, not middleware tricks, so the invariants are reachable from `pytest`. The Tool and DataSource registries are not inheritance hierarchies — they are Python protocols registered at startup; a new tool is a class that satisfies `(I) Tool`, dropped in a module, and the registry picks it up with no changes to the agent.

3. Use Cases

Use-Case Lanes · E2 · F1 · F4

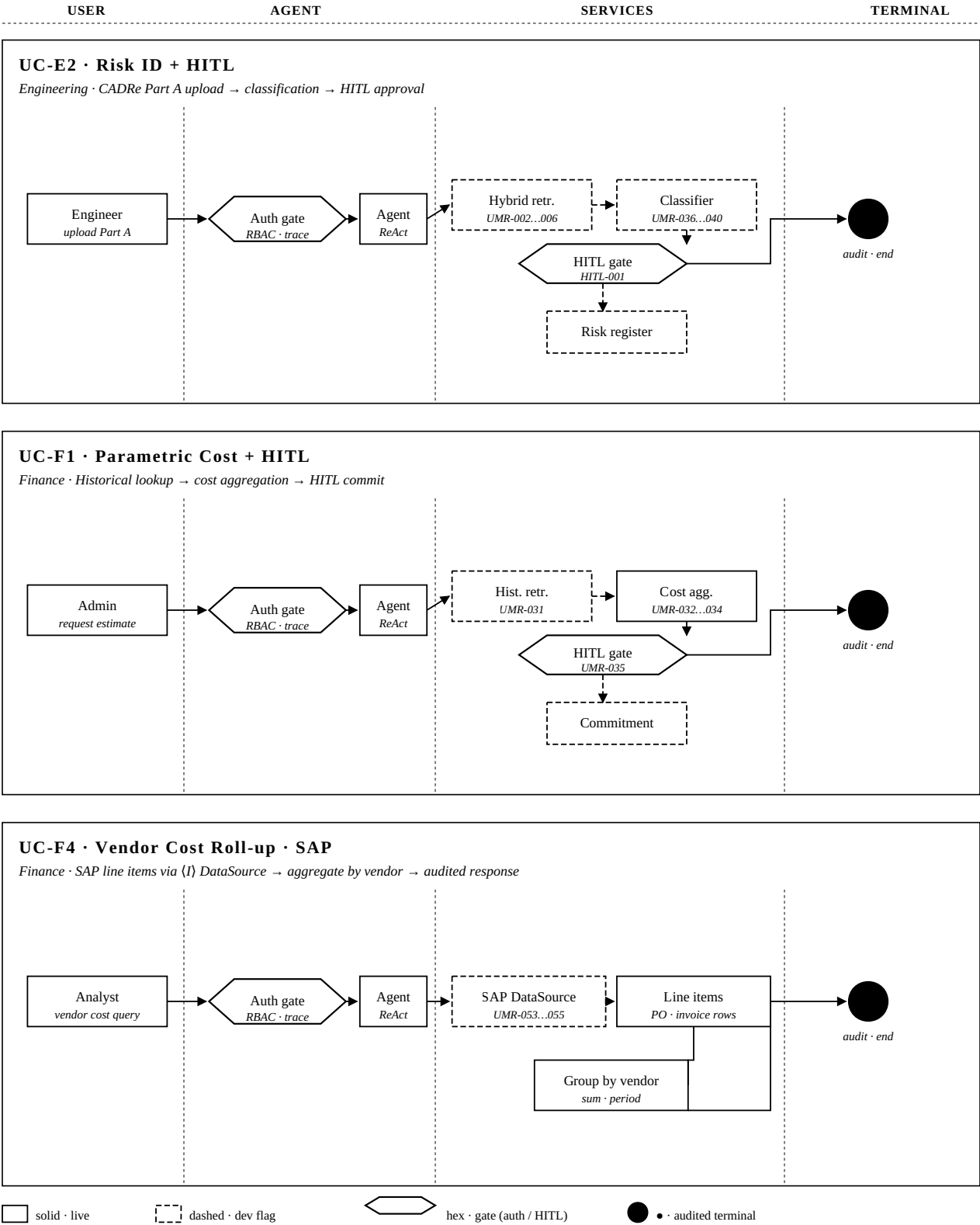


Figure 3 · Three use-case lanes left-to-right with UC IDs.

Three lanes exercise the full spine: **UC-E2** (Engineering risk ID + HITL) runs the full retrieval → classify → human-gate → register path. **UC-F1** (parametric cost + HITL) runs the historical-lookup → aggregate → human-gate → commit path. **UC-F4** (vendor cost via SAP) runs the connector-based retrieval → aggregate path, with the SAP backend behind the same **{I}** `DataSource` as `LocalFile` so the lane shape is identical whichever backend is live. Every other mission flow (budget scenarios, anomaly triage, bilingual reports, cross-mission compare) attaches as a new `Tool` + optional `DataSource` along the same lanes.

4. Design Decisions & Component Rationale

Component	Role	Why this choice
Flask	Public HTTP surface	Mature, standards-based WSGI; routes are the integration contract — any external agent or scheduler can trigger CRAFT with no SDK.
LangGraph	Primary agent runtime	First-class <code>interrupt</code> for HITL, bounded recursion, graph-level test anchors. Actively maintained by LangChain Inc.; standard ReAct pattern.
Dash	HITL reviewer UI	Shares the Flask process and auth, so the reviewer surface inherits RBAC without a second deployment.
Azure OpenAI	LLM inference	Canadian-region deployment satisfies PBMM data-residency; enterprise SLA; swappable behind {I} <code>ChatProvider</code> .
Azure AI Search	Hybrid retrieval	Vector + BM25 in one service; managed; swappable behind {I} <code>DataSource</code> .
Azure Content Safety	Guardrails	Microsoft-maintained moderation; invoked through a tool wrapper so the control plane stays swappable.
Azure Container Apps	Code-exec sandbox	Isolated per-request containers; standard scale-to-zero; satisfies UMR-093.
Azure App Service (PBMM)	Runtime	PBMM Canadian region, managed TLS, blue-green deploy, zero-trust networking into APIM.
APIM + App Gateway	Edge	WAF + rate limit at the perimeter; terminates mTLS; makes CRAFT addressable without exposing App Service directly.
Entra ID + MSAL	Identity	CSA-standard identity; MSAL is Microsoft-maintained; token flow identical for human and agent callers.
Log Analytics	Audit sink	Immutable retention policy satisfies UMR-027 audit grade; KQL-queryable.
Postgres	HITL approval queue	Durable queue state across restarts; mature; backs the Dash reviewer UI.
SQLite	WorkspaceStore / DataStore	File-local, zero-ops for scratch + per-user scoped data; swappable behind {I} <code>WorkspaceStore</code> when a managed DB is in place.
Python protocols	Extension boundary	Structural typing — a new tool or data source is a class satisfying the protocol, no base class, no registry edit, no agent change.
pytest + pyright + ruff	Architecture invariants	Industry-standard, actively maintained; invariants ship as tests (route × role matrix, protocol contracts, audit envelope present).

5. Abstraction for the Future

Four protocol boundaries carry the extensibility story. Each one is a single Python file; adding a backend behind one of them is additive and leaves the agent untouched.

Protocol	What it abstracts	How future growth lands
{I} <code>Tool</code>	Any callable capability the agent can invoke	New capability = new class satisfying the protocol. Agent code unchanged. Validated by <code>test_tool_contract</code> .
{I} <code>DataSource</code>	Any corpus or system of record	SharePoint, SAP, STK, a future vector index — each is a class; the agent calls them identically.
{I} <code>ChatProvider</code>	The LLM runtime	Lets us swap inference backends behind one interface; sub-agents become new graph nodes under the same provider.
{I} <code>WorkspaceStore</code> / {I} <code>AgentActionLog</code>	Session state and audit sink	SQLite today, managed DB tomorrow; JSONL today, Log Analytics tomorrow — same call site.

External accessibility. Routes are the integration contract. `POST /chat/send`, `POST /chat/upload`, `POST /tools/execute/<name>` and `GET /admin/*` are reachable by any external principal that holds an Entra token with the required role — a human in the Dash UI, a scheduled job, a Teams bot, or an upstream orchestrator agent. That means CRAFT can be *triggered* (cron, webhook, agent) and *embedded*

(as a tool for a larger agent) without new code. Deployment is a container image; the APIM policy decides which callers can reach which routes.

6. Requirements → Design

CAPABILITY	REQUIREMENTS	ABSTRACTION POINT	USE CASES
Primary agent	UMR-001/011/013/016/018/019/094/095, AAR-001/003/006, ASG-005	LangGraph ReAct · {I} ChatProvider · recursion_limit=25	E2, F1, F4
Retrieval + RAG	UMR-002/003/004/005/006/009/010/060/067, ARR-002-007	Azure AI Search (hybrid vector + BM25) · {I} DataSource + {I} Tool	E2, F1
Audit + traceability	UMR-015/027/045/061/062/093, AAR-005, ASG-003	AgentAction envelope · {I} AgentActionLog · JSONL → Log Analytics	E2, F1, F4
HITL approvals	UMR-021-026/035/039/044/049, HITL-001-007, ASG-002	LangGraph interrupt · Postgres queue · Dash review UI	E2, F1
RBAC + data scoping	UMR-012/017/058/065/066, AAR-002/007	_ROUTE_RULES + _ROLE_LEVEL · SqliteDataStore · QueryTool.set_user	E2, F1, F4
Session + workspace	UMR-014/092/095	{I} WorkspaceStore → SqliteStore + SessionScratchStore	all
Guardrails + containment	UMR-020/029/030, ASG-001/004/011	Azure Content Safety · APIM rate limit · Container Apps sandbox	all
Connectors + external	UMR-051-055	{I} DataSource + MSAL · Flask REST · SAP / STK / MATLAB adapters	F4
Domain capabilities	UMR-007/008/031-034/036-038/040-043/046-048/050/075, ARR-001	New {I} Tool instances over existing abstraction points	E2, F1
Deployment, SLA	UMR-028/056/057/059/064/069/070/074/085, ASG-006	Azure App Service PBMM · APIM + WAF · SSC LaunchPad HA · git config	all

7. Development Flags & System-Health Tooling

ITEM	KIND	OWNER / TOOL	NOTES
Azure AI Search	Dev flag	IT	Hybrid retrieval + citations. Abstraction: {I} DataSource.
Log Analytics + immutability	Dev flag	IT	Tamper-proof audit sink. Abstraction: {I} AgentActionLog.
Content Safety + Container Apps	Dev flag	Procurement	Guardrails + sandboxed code exec. Abstraction: CodeExecTool.
Entra ID + SharePoint / SAP	Dev flag	IT + Finance	CSA corpus + cost data. Abstraction: {I} DataSource.
CSA risk taxonomy	Dev flag	Domain	Risk ID + HITL classification.
Historical mission DB	Dev flag	Finance	Parametric cost estimation.
ruff	Health	pre-commit + CI	Lint (flake8 + isort + pyupgrade).
pyright	Health	pre-commit + CI	Strict type checking.
pytest + coverage	Health	pre-commit + CI	156 tests, 91% coverage.
bandit	Health	pre-commit	Security scan.
pip-audit	Health	pre-commit	Dependency CVE audit.
detect-secrets	Health	pre-commit	No credentials in git.